



by **Joshua Copeland**
Contributor

The cybersecurity backlog is not a security problem

Opinion

Aug 14, 2026 • 8 mins

A giant security backlog? The real problem may be who owns the fixes, not the security team tracking them.



Credit: testing / Shutterstock

Cybersecurity teams should be responsible for risk oversight, rather than for executing every corrective action. Assigning security teams the tasks of finding, prioritizing,

assigning, implementing, tracking and validating every remediation does not foster accountability. Instead, it results in an organizational repository for unresolved issues.

A more effective model distinguishes roles clearly: security functions as the overseer, while technology and business operations execute remediation. Security should maintain the authoritative risk inventory, determine priorities, establish remediation standards, escalate missed commitments and verify closure. Owners of the affected infrastructure, cloud environment, application, identity platform or business process are responsible for implementing fixes. Executives are tasked with resolving resource conflicts and explicitly accepting risks that the organization elects not to remediate.

This distinction is substantive, as it determines whether a vulnerability management program effectively reduces risk or simply generates remediation tickets.

An increasing backlog indicates a failure in the operating model

Security teams often become the default owners of any issue labeled as a security concern. For example, when a scanner identifies an outdated package, security is expected to patch the server. If a cloud security platform detects an exposed storage bucket, security is tasked with redesigning the deployment. Similarly, when an audit reveals excessive privileges in a business application, security is expected to negotiate access changes with the department responsible for the workflow.

This dynamic arises because discovery is highly visible, while remediation is often inconvenient. When the security team produces a report, the organization may assume that the team is also responsible for implementing the solutions. Over time, infrastructure, engineering and business owners come to expect that security will initiate tickets, provide instructions, schedule meetings, monitor deadlines, request exceptions and communicate delays to leadership. As a result, the actual system owner becomes a participant in a process that should have been their primary responsibility.

The resulting backlog is often attributed to the security team, as they maintain the dashboard. However, the dashboard merely reveals a broader organizational failure: ownership was never assigned to the asset, remediation work was not incorporated into operational capacity and leadership did not establish clear decision-making authority regarding when reliability, product delivery, customer commitments or technical debt should be deprioritized in favor of risk reduction.

NIST's Cybersecurity Framework 2.0 [<https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>] emphasizes governance, prioritization and communication of cybersecurity risk throughout the organization. It does not recommend that the security function personally execute every remediation. Similarly, **NIST's enterprise patch management guidance** [<https://csrc.nist.gov/pubs/sp/800/40/r4/final>] characterizes patching as preventive

maintenance and a standard business cost, rather than a specialized task performed solely by the security team.

A backlog is not merely a compilation of technical weaknesses; it represents a record of unresolved organizational decisions. Each aging item reflects unanswered questions, such as: Who owns the system? Who has the authority to implement changes? What business impacts must be considered? What capacity is available? Who is authorized to accept the remaining risk?

Security is responsible for maintaining the risk record, while system owners are accountable for executing remediation

The most effective way to preserve accountability is to define responsibilities prior to the identification of new findings.

Security should own the authoritative inventory of known risk. That includes validating findings, removing duplicates and false positives, connecting technical weaknesses to affected assets and business services, assigning risk-based priority, defining minimum remediation evidence, escalating overdue items and independently verifying closure. Security should also identify patterns. Ten nearly identical cloud misconfigurations are not ten unrelated tickets; they are evidence of a broken deployment standard, missing automation or weak preventive control.

Prioritization should extend beyond simple severity scoring. The Cybersecurity and Infrastructure Security Agency (CISA) recommends using **its Known Exploited Vulnerabilities Catalog** [<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>] as an input for vulnerability management prioritization, as it highlights vulnerabilities with evidence of active exploitation. For instance, a critical vulnerability on an isolated test asset may warrant less urgent action than a lower-scored weakness that is internet-facing, associated with privileged access, or actively exploited. Security teams are best positioned to make these distinctions due to their comprehensive understanding of threat and control contexts.

Remediation execution should be the responsibility of the teams that own the relevant technology or process. Infrastructure teams are tasked with patching and reconfiguring servers and endpoints. Cloud platform teams address identity, network, storage and logging controls. Application teams update dependencies and redesign vulnerable code, while business system owners approve workflow and access changes. These teams possess the necessary understanding of dependencies, testing requirements, outage risks and operational consequences, as well as control over the engineering mechanisms required for durable solutions.

Executives own the decisions that neither security nor system owners can resolve. When a remediation commitment conflicts with a product launch, customer obligation, reliability concern or budget constraint, the issue has become a management decision. Leadership must choose to provide capacity, change the deadline, approve a compensating control or accept the risk. Silence is not risk acceptance. Allowing a finding to age because every team has more urgent work is unmanaged risk with no accountable decision. This model also redefines performance metrics. Security should be evaluated based on coverage, validation speed, prioritization quality, escalation timeliness and closure verification. Remediation owners should be assessed on risk reduction, the aging of high-priority findings, recurrence rates and the proportion of work eliminated through automation or permanent design changes. Executives should monitor backlog growth relative to available capacity, unresolved resource conflicts, expired exceptions and the volume of risk accepted without a funded treatment plan

No organizational function should be held accountable for tasks beyond its control.

Backlogs are resolved through increased capacity, not by implementing additional service-level agreements

Many organizations address a growing backlog by introducing stricter service-level agreements, such as requiring critical findings to be resolved within 15 days and high-priority findings within 30 days. While policies may change and dashboards reflect increased urgency, the underlying remediation capacity often remains unchanged. An SLA is a commitment, not a source of labor. **A recent CSO article made a related point** [<https://www.csoonline.com/article/4169623/why-patching-slas-should-be-the-floor-not-the-strategy.html>]: patching SLAs should be the floor, not the strategy, because green compliance metrics can hide the small number of difficult risks that matter most. Deadlines are useful only when the responsible teams have the authority, skills, maintenance windows, testing environments and engineering time required to meet them.

This issue is particularly significant when an organization inherits substantial technical debt. Thousands of legacy vulnerabilities, unsupported systems, cloud misconfigurations, identity weaknesses and audit findings cannot be simply assigned to engineering teams already committed to ongoing operations and strategic initiatives. Such an approach does not constitute a viable remediation plan. Overloaded teams are unlikely to generate additional capacity solely based on the importance of the backlog.

At a certain scale, organizations should allocate resources to a temporary remediation team dedicated to eliminating historic risk debt and establishing a sustainable operational cadence. This team should be time-limited, separately funded and composed of personnel with expertise in infrastructure, cloud, application, automation and program management, enabling them to implement changes directly rather than merely coordinate efforts. Security should retain responsibility for prioritization and independent validation, rather than serving as the primary remediation workforce.

The temporary remediation team should address categories of problems rather than individual tickets. Its responsibilities include developing automated patching and configuration baselines, replacing unsupported components, correcting reusable infrastructure templates, removing abandoned assets, standardizing evidence collection and identifying systems that require executive decisions instead of repeated exceptions. **NIST’s 2026 guidance, which links cybersecurity risk, enterprise risk management and workforce planning, [https://csrc.nist.gov/pubs/sp/1308/final]** reinforces the principle that risk responses and workforce decisions must be coordinated.

The activation of this team should not be based on an arbitrary number of findings, but rather on a persistent imbalance between incoming risk and remediation capacity. Indicators include a consistently growing backlog, high-risk findings that exceed normal change cycles, recurring weaknesses or remediation efforts that would require multiple quarters of existing capacity. These conditions provide leadership with evidence that standard operations are insufficient to restore the program.

Exit criteria should be clearly defined: eliminate the historic high-risk backlog, reduce remaining work to a manageable level for standard teams, automate recurring fixes, assign each asset to an accountable owner and establish a measurable cadence in which new high-priority risks are resolved more quickly than they are generated. A cybersecurity backlog does not indicate failure on the part of the security team. Rather, it demonstrates that the organization has separated the authority to identify risk from the capacity and accountability necessary to address it.

Security should be responsible for monitoring, validating, prioritizing, escalating and verifying risk. System owners should implement remediations and executives should make strategic decisions. Unless these responsibilities are explicitly defined and appropriately resourced, the backlog will persist regardless of the number of scanners, tickets, dashboards or service-level agreements introduced.

Security Practices[https://www.csoonline.com/security-practices/]	Security[https://www.csoonline.com/security/]
IT Management[https://www.csoonline.com/it-management/]	IT Leadership[https://www.csoonline.com/it-leadership/]



Policies



More



Our Network

